Konecta

Checklist para Certificación de Seguridad de aplicaciones web

Id	Criterio		Clasificación
1	El repositorio cuenta con una estructura definida que permite diferenciar la documentación, los archivos de producción y de desarrollo		Alta
2	El código instalado en el servidor de pruebas es igual al enviado en el repositorio a excepción de los apuntamientos		Crítica
3	La aplicación cuenta con un ambiente de pruebas estable que permite la ejecución de la auditoria de seguridad		Crítica
4	La aplicación tiene instalado un certificado digital que permite las conexiones seguras por HTTPS		Crítica
5	Se encuentra la documentación de la aplicación en el repositorio	Manual tecnico	Alta
6		Manual de salida a producción	Alta
7	La lógica de la aplicación se encuentra separada según el lenguaje y puede diferenciarse el back, el front y los archivos de configuración		Alta
8	El escaneo de Sonarqube con el perfil de seguridad contiene solo aquellos hallazgos que no pudieron ser solucionados y están debidamente argumentados en el código		Crítica
9	No se encuentran líneas de código comentadas que no hacen parte de la documentación del código o de la que ofrece el lenguaje de programación		Media
10	No existe código que no hace parte del funcionamiento de la aplicación		Media
11	No existen comentarios que incluyan datos de prueba o información de un usuario/cliente		Alta
12	No existe lógica de desarrollo en el código de producción. La única diferencia entre ambos ambientes es el archivo de configuración		Crítica
13	Todos los datos de configuración como IPs, URLs, puertos, usuarios, contraseñas y demás se encuentran almacenados en un archivo destinado para este fin		Alta
14	No se encuentran clases, ciclos, instrucciones de decisión o métodos sin lógica interna		Media
15	Todas las instrucciones de decisión cuentan con la cláusula de finalización apropiada, por ejemplo los switch finalizan con la cláusula default y los else if con la cláusula else		Media
16	No se encuentran variables sin preinicialización		Media
17	No se realizan impresiones por consola ni se imprime información sensible en mensajes de alerta o error		Crítica
18	Las excepciones capturadas por las instrucciones catch son registradas en el log de errores o está documentado en el código la razón por la que no es almacenado		Alta
19	Todas las conexiones se realizan por medio de protocolos seguros como HTTPS, SFTP, SMTP y demás		Crítica
20	No se utilizan funciones inseguras como eval(), error_reporting, entre otras		Alta
21	No se almacenan claves, llaves y otros datos de acceso de desarrollo ni de producción en el repositorio		Crítica
22	Se utilizan algoritmos de cifrado fuertes		Crítica
23	Solo se hace uso de emails corporativos o aprobados por el cliente para el envío de notificaciones o información de la aplicación. Para las aplicaciones institucionales solo se permite la creación de usuarios con el correo corporativo		Alta
24	No se utilizan usuarios con privilegios como root, admin, administrador, entre otros		Alta
25	Las consultas SQL se encuentran definidas correctamente, cumpliendo con las recomendaciones de seguridad según el lenguaje utilizado		Crítica
26	Existe un log que registra los intentos de acceso a la aplicación, especialmente los fallidos. Se almacena el usuario, IP, fecha y hora		Alta
27	Existe un log que contiene la trazabilidad de todas las acciones realizadas, acompañadas con el nombre de usuario, fecha, hora y la dirección IP		Alta
28	Existe un log que contiene los errores capturados y generados por la aplicación		Media
29	No se almacena información sensible o confidencial de los clientes o usuarios. Solo se almacena la mínima información necesaria para identificar la transacción		Crítica
30	Las librerías y herramientas utilizadas por la aplicación se encuentran en una versión actualizada y sin vulnerabilidades de seguridad conocidas		Crítica
31	Se utiliza una versión del lenguaje actualizada y sin vulnerabilidades de seguridad conocidas		Crítica
32	Los elementos vinculados a una página de destino abierta con target="_blank" tienen configurada la etiqueta rel="noopener noreferrer" para evitar los ataques de tabulación inversa		Alta
33	Todas las etiquetas de script o de enlace que hacen referencia a un servidor externo tienen correctamente configurado el atributo de integridad para evitar la inyección de contenido malicioso		Alta
34	Los Web service consumidos por la aplicación tienen un método de autenticación que permite el consumo seguro de la información		Crítica
35	No se hace uso de aplicaciones o servicios que tengan implementados métodos de autenticación inseguros, ni se implementan estos métodos en la aplicación		Crítica
36	En el almacén de confianza se incluyen los certificados de todos los servicios consumidos y estos se encuentran vigentes		Crítica
37	No se asignan todos los permisos de lectura, escritura y ejecución a ningún componente o usuario		Alta
38	La autenticación de la aplicación se realiza con los usuarios de red definidos en el LDAP de la compañía o con un sistema propio que cumple con todos los requisitos definidos en este		Crítica
39	Se implementa un método de protección contra ataques automatizados como los captcha		Alta
40	Se indica en la interfaz de la aplicación el nombre de usuario al que pertenece la sesión		Alta
41	La aplicación cuenta con un botón de deslogueo que cierra la sesión e invalida los datos para que no puedan ser utilizados nuevamente		Alta
42	No se puede establecer más de una sesión simultánea con un mismo usuario		Alta
43	No se muestran las IPs utilizadas en ningún componente de la aplicación como la interfaz, la consola del desarrollador, el código accesible por el cliente o los encabezados de respuesta		Crítica
44	La opción de autocompletar se encuentra desactivada en todos los campos y no se almacenan datos utilizados anteriormente en la aplicación		Alta
45	La opción copiar y pegar se encuentra deshabilitada para los campos que contienen información sensible		Alta
46	No se puede acceder a los archivos del servidor mediante el navegador		Alta
47	No se puede acceder o modificar la lógica de la aplicación mediante el navegador o esta no se encuentra en texto plano cuando el lenguaje utilizado requiere que sea público		Crítica
48	La información bancaria se muestra enmascarada en la aplicación y no se almacena en ningún medio. La información se almacena cifrada o enmascarada en la base de datos con autorización escrita del cliente y su respectiva justificación		Crítica
49	No se puede acceder a los archivos confidenciales de la aplicación mediante el navegador		Crítica
50	Se hace uso del protocolo HTTP/2		Baja

51	La sesión se cierra por inactividad sugerida de 300 segundos, inhabilitando los datos de sesión y redirigiendo a la página de login	Crítica
52	Las cookies utilizadas por la aplicación cuentan con todas las configuraciones de seguridad como la bandera asegurada, el sameSite, el httpOnly y demás	Crítica
53	Los errores que se muestran en la aplicación son genéricos y dan información específica de la causa sin brindar información detallada de librerías, versiones, nombres de archivos y demás	Crítica
54	No se almacenan datos sensibles de la sesión que permitan el escalamiento de privilegios en el storage. Adicionalmente los datos de sesión son válidos únicamente en la IP donde fueron generados	Crítica
55	Los datos de sesión son válidos únicamente cuando hay actividad en la aplicación, el token tiene definido el tiempo de expiración y los datos se invalidan si hay un time-out	Crítica
56	Todos los campos de la aplicación cuentan con validación de contenido, permitiendo únicamente los caracteres esperados según el tipo de dato. Además no permiten inyecciones de código	Alta
57	Todos los campos de la aplicación cuentan con validación de tamaño según el dato esperado	Alta
58	Se valida el tamaño y la extensión de los archivos antes de cargarlos en la aplicación	Alta
59	Se valida que el contenido del archivo sea el esperado según la extensión	Alta
60	Se validan los certificados de todos los servicios que van a ser utilizados incluyendo WS, aplicaciones web, sftp,smtp, BD y demás antes del intercambio de información para asegurar la conexión al sitio correcto	Alta
61	Existe una política donde se especifica el proceso de depuración de los archivos almacenados por la aplicación en el servidor	Media
62	No es posible realizar el consumo de la aplicación mediante el protocolo http	Alta
63	Todos los formularios de la aplicación tienen correctamente configurado el token anti-CSRF para evitar el ataque de solicitudes falsas entre sitios	Alta
64	Los CORS de la aplicación se encuentran correctamente configurados para evitar el intercambio de información con sitios no permitidos	Alta
65	Los métodos TRACE, OPTIONS y TRACK se encuentran deshabilitados, las cabeceras "Server" y "X-Powered-By" no muestran información de las herramientas utilizadas y las páginas de error se encuentran personalizadas	Alta
66	El framework utilizado no está configurado en modo de desarrollo o debug para evitar la exposición de información sensible	Alta
67	Todos los encabezados HTTP de seguridad se encuentran bien configurados en el servidor	Alta
68	Todos los encabezados HTTP de seguridad se encuentran bien configurados en el código	Alta
69	No se envían parámetros por medio de la URL, ni se consumen servicios externos con este método	Alta
70	Se tiene la justificación del motivo por el que es necesario utilizar los métodos PUT y DELETE	Media
71	No es posible detectar si un usuario es válido a partir de la respuesta obtenida en una solicitud	Crítica
72	Todos los módulos de la aplicación funcionan correctamente y permiten la realización de todas las pruebas de seguridad. Existen para cada módulo datos de prueba	Crítica
73	Se realiza el escalamiento a las áreas de Konecta encargadas de las aplicaciones consumidas por la aplicación para la certificación de seguridad del componente	Baja
74	Se realiza el escalamiento al cliente o al área encargada cuando una aplicación consumida por la aplicación no cumple con algún requisito de seguridad. Por ejemplo, WS sin autenticación, uso de método GET, servicios http, contraseñas inseguras, etc	Baja